Lumi Reading · Security & Privacy Evidence

EV7

Business Continuity Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV7 (business continuity plan) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

---

1. Purpose and scope

This plan describes how schools keep operating when Lumi Reading is degraded or unavailable, how Lumi communicates during a disruption, and the order in which service is restored. It is the availability counterpart to the disaster-recovery plan (`docs/security/evidence/EV8_DISASTER_RECOVERY_PLAN.md`, which covers data loss/corruption and the technical restore) and the incident-response plan (`docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md`, which covers security incidents). Where a target is an expectation rather than a measured, drilled figure, it is called out (§10).

Scope: a loss or serious degradation of the availability of Lumi to schools, teachers, parents or children — whether caused by the underlying platform (Firebase / Google Cloud, `australia-southeast1`), by a Lumi change (a bad deploy or rules regression), or by a dependency (the app stores, SendGrid, Twilio, the status worker). Security incidents are in scope of this plan only for their availability impact; their handling is governed by EV9.

2. What "continuity" means for Lumi

Lumi is a supplementary reading-tracking tool, not a system a school depends on minute-to-minute to run its day. The continuity objective is therefore:

1. **no loss of a child's reading data** during an outage (the data-integrity objective — met primarily by on-device capture, §4, and by the backups in EV8); and
2. **a fast return to normal logging and visibility**, with clear communication while service is impaired.

Most of Lumi's availability is **inherited** from Google Cloud / Firebase, which Lumi cannot itself restore; Lumi's continuity actions are (a) preserving data at the edge so an outage does not destroy work, (b) communicating out-of-band, and (c) restoring Lumi's own code/config quickly when Lumi is the cause.

Key dependency note: the in-app status banner is served by an **independent Cloudflare worker**, deliberately *not* on Firebase, so it can still reach users during a Firebase outage (§5). This independence is a designed continuity property (`docs/status-messages.md`).

3. Disruption scenarios

Scenario	Primary effect	Lumi's continuity response
Platform (Firebase/GCP) outage	App can't sync; portals down	Reading still captured on-device (§4); publish status banner (§5); monitor Google status; restore follows Google
Lumi-caused outage (bad deploy, rules regression)	Feature broken or access denied/over-permissive	Roll back to last known-good revision/ruleset; feature kill switch where applicable; status banner; this is also an EV9 event if security-relevant
Malicious / unsafe app release	Bad client version in the field	Force-update / support mode via minimum-version policy points users at a safe build (§5)
Dependency outage (SendGrid, Twilio, app store)	Emails/SMS/onboarding delayed	Core logging unaffected; degrade the dependent feature; communicate if user-visible
Status-worker outage	Can't publish a banner	Fall back to direct school email (§5); clients keep their last cached banner and fail safe

4. Keeping schools operating during an outage

- **On-device reading capture (primary continuity control).** The app persists its working data locally (offline caches for students, reading logs and a pending-sync queue), so a child's reading can still be logged while Lumi's backend is unreachable; queued entries sync when service returns. This is the behaviour the outage status message promises users ("your reading still saves locally", `docs/status-messages.md`). On a cold start with no cached policy and a transient transport failure, the app continues into itself and retries (2/5/15/30/60 s) rather than blocking.
- **Manual / paper fallback (extended outage).** If Lumi is unavailable for an extended period beyond on-device buffering, schools revert to their existing paper reading-diary practice (the pre-Lumi norm) and staff re-enter the totals once service is restored. Note the accountability constraint: parents cannot backdate reading in the app by design, so post-outage catch-up of paper records is entered by teachers/staff, not retro-dated by parents (see `docs/CLASSROOM_BETA_READINESS_REVIEW.md`).
- **Read-only visibility degrades gracefully.** Dashboards/reports and non-essential features (comprehension AI evaluation, notifications, awards) are allowed to degrade or pause first; they are not required for a child to keep reading and being logged.

5. Communication channels

- **In-app status banner (all users, out-of-band).** The operator publishes a banner via the Cloudflare status worker using `scripts/status-message.sh`, at `info` / `warn` / `critical` severity (critical is non-dismissible); the client polls at ≤60 s. Runbook: `docs/status-messages.md`. Typical outage workflow: confirm the outage → publish a `warn` ("Lumi is having trouble — your reading still saves locally.") → escalate to `critical` if needed → `clear` on resolution → optional post-mortem `info`.
- **Force-update / support mode.** The `minAppVersion` policy can block an unsafe client version behind an update screen and point users at a safe build; a malformed policy fails *into* support mode (fail-safe).
- **Direct school communication.** For anything a school must act on (or if the status worker itself is down), schools are contacted through a **separately verified emergency contact** held in the contract/CRM — never

assumed to be a possibly-affected in-app account (this register is the same one EV9 depends on; it is a known gap, §11).
- **Wording discipline.** All external messages are plain, child-safe and speculation-free (shared with the EV9 communications rules).

6. Recovery priorities

Restore in this order; never trade a security regression for availability:

1. **Confidentiality and integrity of child data** — a fix must not reopen a tenant-isolation or access-control gap (verified against the reviewed known-good baseline, EV9 §7).
2. **Reading-log capture and sync** — the core school workflow; drain the on-device pending-sync queue safely.
3. **Parent/teacher visibility** — dashboards and reports.
4. **Administrative functions** — portal provisioning, allocations, onboarding.
5. **Enhancement features** — AI comprehension evaluation, notifications, awards (these degrade first and restore last).

7. Target recovery expectations

These are **operating targets**, not drilled guarantees (§10), and are bounded by the platform's own restoration for a Google-side outage:

Objective	Target
Publish an in-app status banner after a confirmed user-visible outage	within ~30 min
Notify affected schools' emergency contacts (if action needed)	same business day
Roll back a Lumi-caused outage (deploy/rules) to last known-good	within the deploy/rollback window (EV13 §8)
Data-loss recovery point / restore time (RPO / RTO)	see EV8 (PITR 7-day window; RTO/RPO targets there)
Platform (Google-side) outage	recovery follows Google Cloud restoration; Lumi communicates and resyncs

8. Roles

Continuity is run by the same small team as incident response (EV9 §2): the Security/Technical Lead (Nic, Director) decides on rollback, kill switches, status-banner publication and force-update; the same person coordinates school communication via the verified emergency contact until delegated. Every action is recorded (shared with the EV9 register where the disruption is also an incident).

9. Testing and review

- This plan is reviewed at least annually and after any significant disruption.
- The status-banner path is exercised in practice (the runbook documents the real outage workflow); the data-restore path is exercised via the DR drill (EV8 §7).

- A combined continuity/DR walkthrough should be run on the same cadence as the security breach tabletop (`docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md`) — see the gap in §11.

10. Supporting evidence index

Control	Evidence
In-app status banner (independent of Firebase)	`docs/status-messages.md`, `scripts/status-message.sh`, Cloudflare status worker
On-device offline capture + pending-sync queue	app offline caches (students / reading_logs / pending_sync); `docs/status-messages.md` cold-start behaviour
Force-update / support mode	`minAppVersion` policy (`docs/status-messages.md`)
Rollback / feature kill switches	`docs/security/evidence/EV13_SECURE_SDLC.md` §8
Data recovery (RTO/RPO, backups, restore)	`docs/security/evidence/EV8_DISASTER_RECOVERY_PLAN.md`
Incident handling (security disruptions)	`docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md`
No-backdating accountability constraint	`docs/CLASSROOM_BETA_READINESS_REVIEW.md`
Paper reading-diary (pre-Lumi practice)	`Physical Reading Diary Images/` (product reference)

11. Known gaps (for the reviewer)

- **School emergency-contact register.** Verified per-school emergency contacts are **not** in the repository; direct school communication (§5) and EV9 notification both depend on this register existing and being current in the contract/CRM. This is the top continuity gap.
- **Recovery targets not yet drilled.** The targets in §7 are operating expectations, not measured figures from a timed continuity exercise; a combined continuity/DR drill (§9) must be run and recorded to substantiate them.
- **Single-operator dependency.** Continuity actions currently rest on one person (the Director); the EV9 backup-lead arrangement should be confirmed for continuity too so recovery does not depend on one individual's availability.
- **Sign-off.** This plan requires the Director's sign-off before it is the governing document.